



CHRIST
UNIVERSITY
BENGALURU, INDIA

Declared as Deemed to be University under Section 3 of UGC Act 1956

CHRIST(Deemed to be University)

Department of Computer Science and Engineering

CSHO634CSP - INTRUSION DETECTION AND INCIDENT RESPONSE

Faculties:

Dr Jenefa J

Dr Daniel D

Mission

Christ University is a nurturing ground for an individual's holistic development to make effective contribution to the nation and the world.

Vision

Excellence and Service

Core Values

Faith in God | Moral Uprightness

Love of Fellow Beings | Social

Responsibility | Respect for Family

Unit 1 - Introduction

Introduction to computer incident, legal environment, Network security and attacks, basics of incident detection, parameters for assessment of intrusion detection, Intrusion detection system and Detection approaches, Misuse detection, anomaly detection, specification-based detection, hybrid detection, and statistics.

Event vs Incident vs Breach

Event

- Observable change in system activity
- **Example:** User login, log entry

Incident

- Violation of policy or unauthorized activity
- **Example:** Malware detected

Breach

- Confirmed compromise of data or system
- **Example:** Customer data leaked

Event vs Incident vs Breach



Classify Each as Event, Incident, or Breach

- User forgets password

Event

- Unauthorized login attempt detected

Incident

- Website defaced

Breach

- High CPU load on server

Event

Classify Each as Event, Incident, or Breach

- Phishing mail received

Incident

- Customer data leaked online

Breach

Computer Security Incident

- Computer security incident to be any event that has the following characteristics:
 - Intent to cause harm
 - Was performed by a person
 - Involves a computing/communicating resource

Examples

- Malware infection
- Unauthorized access
- Data theft or deletion
- Denial of Service attack

Categories of Incidents

- **Malware incidents** – virus, trojan, ransomware infections
- **Unauthorized access** – credential theft, privilege escalation
- **Denial of Service (DoS)** – disrupting availability of services
- **Information disclosure** – accidental or deliberate leaks
- **Policy violations** – misuse of resources or data
- **Insider threats** – employees intentionally causing harm

Incident Response

- Incident response is a structured process to handle and manage incidents efficiently.
- It has six phases.

Incident Response - Phases

- Preparation
- Detection & Analysis
- Containment
- Eradication
- Recovery
- Post-Incident Activity

Preparation

- Establish incident response policies, tools, and trained personnel.
- Define communication plans and escalation procedures.
- Maintain backups and logs.

Preparation - Example

- Company creates an Incident Response Policy.
- IR team trained on how to respond to phishing or ransomware.
- Regular backups and system hardening are done.

Detection & Analysis

- Identify suspicious events or anomalies.
- Analyze alerts, logs, and system behavior.
- Verify whether it's a true incident.
- **Examples:** unusual outbound traffic at midnight, multiple failed logins from foreign IPs, Malware detected by antivirus.

Containment

- Isolate affected systems to prevent spread.
- Disconnect compromised accounts or networks.
- **Example:**
 - Infected workstation is disconnected from the network.
 - Firewall rules are updated to block malicious IP.
 - User accounts temporarily disabled.

Eradication

- Remove malicious files, backdoors, or unauthorized access.
- Apply security patches or configuration fixes.
- **Example:**
 - Delete malware or trojans from infected systems.
 - Remove unauthorized user accounts.
 - Patch exploited software vulnerabilities.

Recovery

- Restore clean backups.
- Monitor systems to ensure they function normally.
- **Example:**
 - Restore data from verified clean backups.
 - Reconnect systems gradually to the network.
 - Monitor for reinfection signs for a few days.

Post-Incident Activity

- Document what happened and how it was handled.
- Conduct a lessons-learned review.
- Update policies and prevention mechanisms.
- **Example:**
 - Conduct “lessons learned” meeting.
 - Update security policies.
 - Prepare a final incident report for management.
 - Train staff on what to do better next time.

Example Case:

Scenario:

A college network experiences a ransomware attack that locks students' project files.

- 1. Preparation:** IT staff had regular backups and antivirus software installed.
- 2. Detection:** A student reports files renamed with “.locked” extension. Antivirus alerts pop up.

Example Case:

3. **Containment:** Network cable unplugged from affected PCs; shared drives disconnected.
4. **Eradication:** Malware files removed; updated patches applied.
5. **Recovery:** Restore project files from backup taken last week.
6. **Post-Incident:** Analyze how malware entered (phishing email). Conduct awareness training.

Legal Environment

Cyber Laws Overview:

- Governed by Information Technology (IT) Act 2000
- Provides legal recognition to e-documents, digital signatures
- Defines cyber offenses and penalties
- To ensure security, accountability, and trust in digital space.

Legal Environment

Section	Description
43	Penalty for damage to computer systems or networks
65	Tampering with computer source documents
66	Computer-related offenses (hacking, unauthorized access)
66C	Identity theft
66D	Cheating by impersonation using computer resources
67	Publishing obscene content electronically
72	Breach of confidentiality or privacy

Role of CERT-IN

- Computer Emergency Response Team – India
- National nodal agency under Ministry of Electronics and IT.
- Coordinates response to computer security incidents in India.

Functions:

- Collect, analyze, and disseminate information on cyber incidents.
- Issue security alerts and advisories.
- Provide incident response support.
- Conduct training and awareness programs.
- Collaborate with international CERTs.

Unit 1 - Introduction

Introduction to computer incident, legal environment, **Network security and attacks**, basics of incident detection, parameters for assessment of intrusion detection, Intrusion detection system and Detection approaches, Misuse detection, anomaly detection, specification-based detection, hybrid detection, and statistics.

Network Security

- Network security refers to the **practice of protecting the integrity, confidentiality, and availability of data and resources** as they are transmitted or accessed over a network.
- It includes **policies, tools, and configurations** that protect networked systems from unauthorized access, misuse, modification, or denial of service.

Network Security

- **Example:**

When you log into your college Wi-Fi using your credentials, network security is ensured through:

Authentication

Encryption

Access Control

Monitoring & Logging

Firewall & IDS

Network Security - Objectives

- **CIA Triad**
- **Confidentiality** - Ensuring only authorized users can access information. **Example:** Using encryption for passwords, emails, etc.
- **Integrity** - Ensuring data is accurate and not altered during transmission. **Example:** Using hashing or digital signatures to check authenticity.
- **Availability** - Ensuring systems and data are available when needed. **Example:** DDoS protection, backup servers.

Types of Network Attack



Passive Attacks

- Passive attacks violate the confidentiality of a system's data without affecting the state of that system

Example: Sniffing and Eavesdropping



Active Attacks

- Active attacks modify the target system.
- Active attacks can affect the availability, integrity, confidentiality, and authenticity

Example: DoS, Man in the Middle

Types of Network Attack



Inside Attacks

An inside attack is initiated from within a network by an authorized user. This may be from someone with malicious intent.

Ex: Theft of physical device, planting key loggers and malwares



Outside Attacks

Caused by an external intruder who does not have authorization to access the network.

Ex: Phishing attack

Common Network Attacks

- Denial of Service (DoS) / Distributed DoS (DDoS)
- IP Spoofing
- Sniffing
- Phishing
- Man-in-the-Middle (MITM)
- Port Scanning
- Session Hijacking

Common Network Attacks

Denial of Service (DoS) / Distributed DoS (DDoS):

- Floods the server with traffic to make it unavailable.
- **Example:** Sending millions of requests to a website.

IP Spoofing:

- Attacker fakes a trusted IP address to gain access.
- **Example:** Pretending to be an internal IP to bypass firewall.

Common Network Attacks

Sniffing:

- Intercepting network packets to read data.
- **Example:** Capturing plaintext passwords with Wireshark.

Phishing:

- Tricking users into revealing credentials.
- **Example:** Fake login page via email.

Common Network Attacks

Man-in-the-Middle (MITM):

- Attacker intercepts and alters communication between two parties.
- **Example:** Altering messages between a user and a bank.

Port Scanning:

- Scanning for open ports before launching attacks.
- **Example:** Using nmap to identify vulnerable services.

Common Network Attacks

Session Hijacking:

- Taking over an active session after authentication.
- **Example:** Stealing session cookies.

Defense Measures

Firewall:

- Filters and blocks unauthorized traffic.
- **Example:** Allows only ports 80/443 for web traffic.

Intrusion Detection System (IDS):

- Detects suspicious or abnormal network activity.
- **Example:** Snort

Defense Measures

VPN (Virtual Private Network):

- Encrypts data transmitted over public networks.
- **Example:** Secure remote access.

Antivirus & Anti-malware:

- Detects and removes malicious software.
- **Example:** Kaspersky.

Defense Measures

Access Control:

- Restricts user privileges.
- **Example:** Role-based access control (RBAC).

Security Policies & Training:

- Educates users to avoid risky behavior.
- **Example:** Phishing awareness training.

Unit 1 - Introduction

Introduction to computer incident, legal environment, Network security and attacks, **basics of incident detection**, parameters for assessment of intrusion detection, Intrusion detection system and Detection approaches, Misuse detection, anomaly detection, specification-based detection, hybrid detection, and statistics.

Incident Detection

- Incident detection is the process of **identifying abnormal or malicious activity** that could indicate a security incident within a computer system or network.
- To recognize attacks and respond before serious damage occurs.

Incident Detection - Purpose

- **Early Warning:** Identify suspicious behavior before it becomes a major issue.
- **Minimize Impact:** Contain attacks quickly to reduce data loss or downtime.
- **Evidence Gathering:** Collect proof for analysis, investigation, or legal action.
- **Continuous Improvement:** Improve defense mechanisms by learning from incidents.

Incident Detection - Sources

- Detection relies on information collected from various systems and tools.
 - System Logs
 - Network Devices
 - Security Tools
 - Applications
 - User Reports

Incident Detection - Sources

System Logs:

- Records from OS and applications
- **Example:** Windows Event Viewer, Linux /var/log/

Network Devices:

- Firewall, router, switch logs
- **Example:** Firewall alerts on blocked IPs

Incident Detection - Sources

Security Tools:

- IDS/IPS, antivirus, SIEM (Security Information and Event Management)
- **Example:** Malware or intrusion detection alerts

Applications:

- Web, DB, or API logs
- **Example:** Repeated login failures

Incident Detection - Sources

User Reports:

- Complaints or manual observations
- **Example:** User reports phishing mail or slowness

Indicators of Compromise (IoCs)

- Indicators of Compromise are clues or evidence that suggest a system may be under attack or has been compromised.
- Types:
 - Network Indicators
 - Host Indicators
 - File Indicators
 - Behavioral Indicators

Indicators of Compromise (IoCs)

- **Network Indicators:** Unusual port activity, unexpected IP communication
- **Host Indicators:** New unknown processes, modified system files
- **File Indicators:** Suspicious file hash or name (e.g., malware.exe)
- **Behavioral Indicators:** User login from unusual location or odd hours

Detection Methods

- Manual Detection
- Signature-Based Detection
- Anomaly-Based Detection
- Heuristic / Rule-Based

Detection Methods

Manual Detection:

- Human observation or reports
- **Example:** User notices strange emails

Signature-Based Detection:

- Matches activity to known attack patterns
- **Example:** Antivirus detects known virus signature

Detection Methods

Anomaly-Based Detection:

- Detects deviations from normal patterns
- **Example:** Sudden traffic spike at midnight

Heuristic / Rule-Based:

- Uses logical conditions or thresholds
- **Example:** 5 failed logins in 2 minutes triggers alert

Steps in the Detection Process

1. **Monitoring:** Continuously observe systems and networks.
2. **Alerting:** Generate alerts when suspicious activity is detected.
3. **Verification:** Validate whether the alert is genuine or false.
4. **Reporting:** Escalate confirmed incidents to the response team.
5. **Documentation:** Record findings for future analysis and improvement.

Challenges in Incident Detection

- **High Volume of Data:** Too many logs and alerts to analyze manually.
- **False Positives:** Many alerts are not real threats.
- **Encrypted Traffic:** Makes inspection and analysis difficult.
- **Lack of Correlation:** Data from different systems not linked properly.
- **Skill Gap:** Requires trained analysts to interpret alerts correctly.

Unit 1 - Introduction

Introduction to computer incident, legal environment, Network security and attacks, basics of incident detection, **Intrusion detection system**, parameters for assessment of intrusion detection, Detection approaches: Misuse detection, anomaly detection, specification-based detection, hybrid detection, and statistics.

Intrusion

- Intrusion is any unauthorized or suspicious attempt to access, modify, or disrupt a computer system, network, or data.
- It may succeed or fail — even an unsuccessful hacking attempt is still called an intrusion attempt.

Examples:

- Trying multiple passwords to guess a login (brute force).
- Scanning ports of a server.
- Injecting SQL commands into a website.
- Malware communicating with a command server.

Intrusion

- **Event** MAY become an **Intrusion** Attempt
- **Intrusion** Attempt MAY become an **Incident**
- **Incident** MAY become a **Breach**

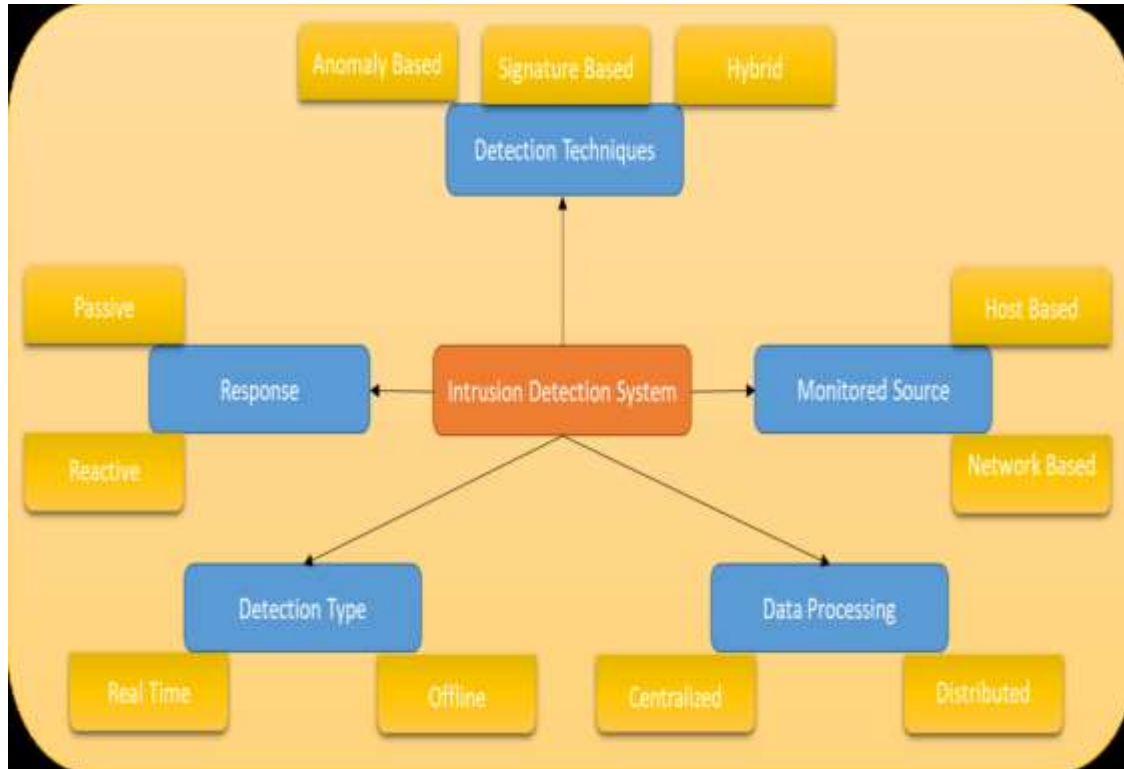
But not all events become intrusions, and not all intrusions become incidents, and not all incidents lead to breaches.

Intrusion Detection System (IDS)

- An intrusion detection system (IDS) is a system that monitors the network as well as hosts to identify unauthorized activities that affect the **confidentiality, integrity, and availability (CIA)** of the data.



IDS Classification



IDS Classification

- Detection Techniques
- Monitored Source
- Response Type
- Detection Type
- Data Processing Architecture

IDS Classification - Detection Techniques

- Method used by IDS to identify a possible attack.
 - Signature-Based Detection
 - Anomaly-Based Detection
 - Hybrid Detection

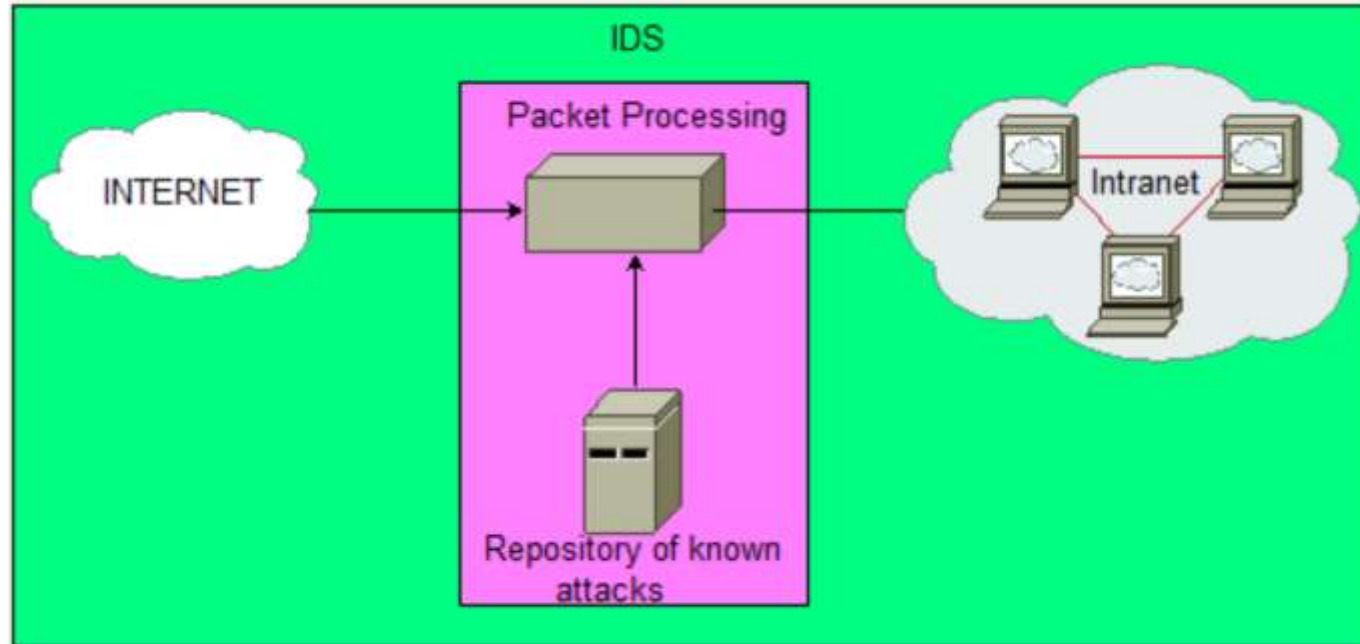
IDS Classification - Detection Techniques

Signature-Based Detection:

- Signature-based detection also called Misuse based detection maintains a database of known attacks.
- The incoming traffic is compared with the signature and the system can identify known attacks in the database.
- Very accurate for known attacks.
- Cannot detect new or unknown attacks.

IDS Classification - Detection Techniques

Signature-Based Detection:



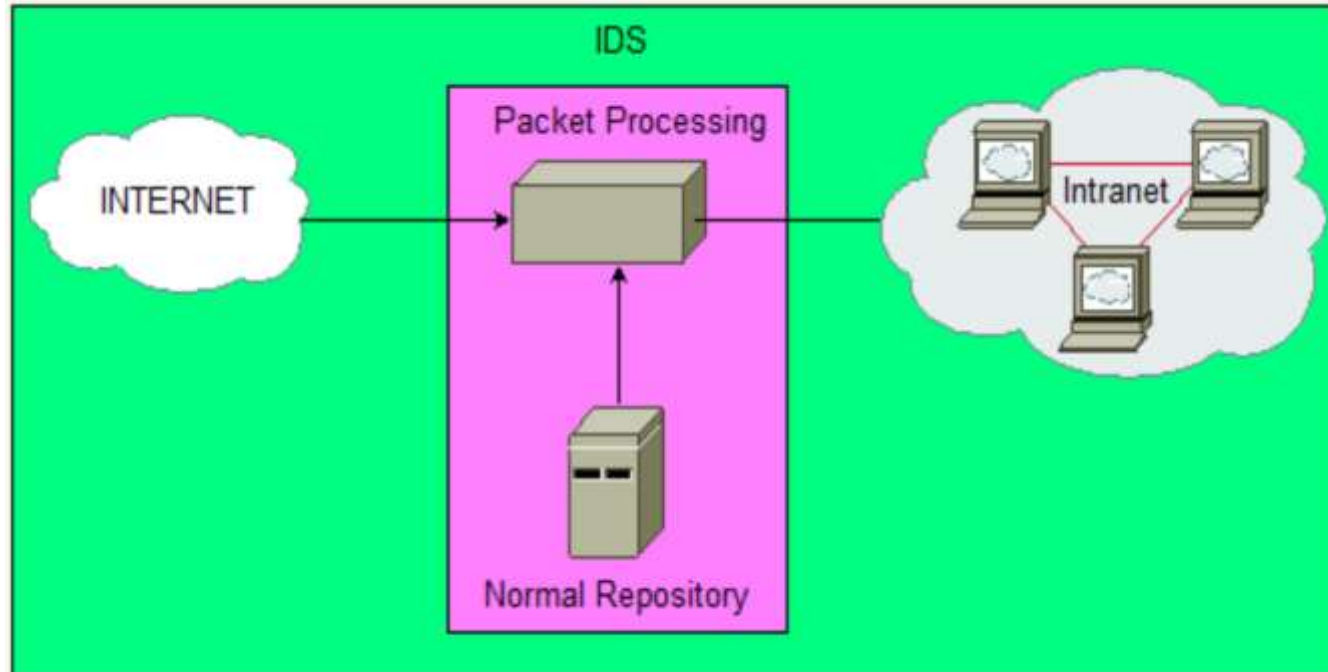
IDS Classification - Detection Techniques

Anomaly-Based Detection:

- In Anomaly-based detection technique, a baseline for normal activities are established and anything that digresses from baseline is classified as an attack.
- Flags anything that deviates from normal.
- Can detect zero-day attacks.
- May produce more false alarms.

IDS Classification - Detection Techniques

Anomaly-Based Detection:



IDS Classification - Detection Techniques

Hybrid Detection:

- Combines signature and anomaly techniques.
- It has advantages of these two approaches and is likewise more ideal than the methodologies utilized independently.
- Used in modern IDS/IPS systems.

IDS Classification - Monitored Source

- Based on the data location being observed by the IDS.
 - Host-Based IDS (HIDS)
 - Network-Based IDS (NIDS)

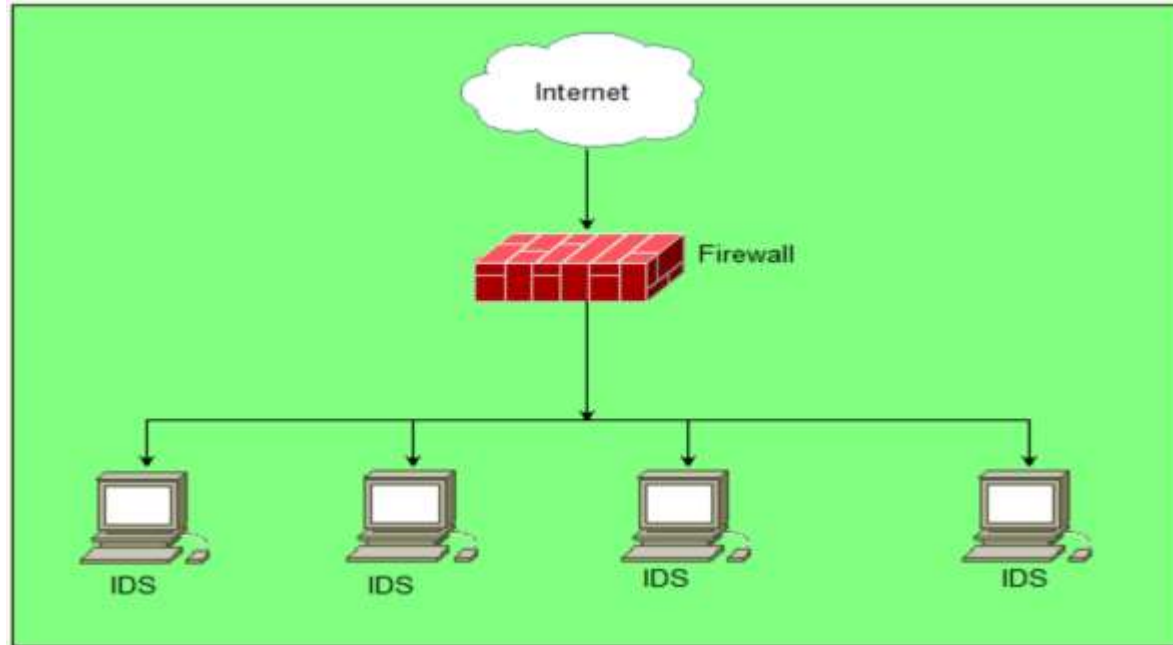
IDS Classification - Monitored Source

Host-Based IDS (HIDS):

- Host IDS are deployed in the hosts that reside in a network and monitors the behavior of the individual hosts for intrusions.
- Runs on individual machines (servers, PCs).
- Monitors system logs, file changes, processes, user activity.
- Detects insider misuse, unauthorized file access, malware.

IDS Classification - Monitored Source

Host-Based IDS (HIDS):



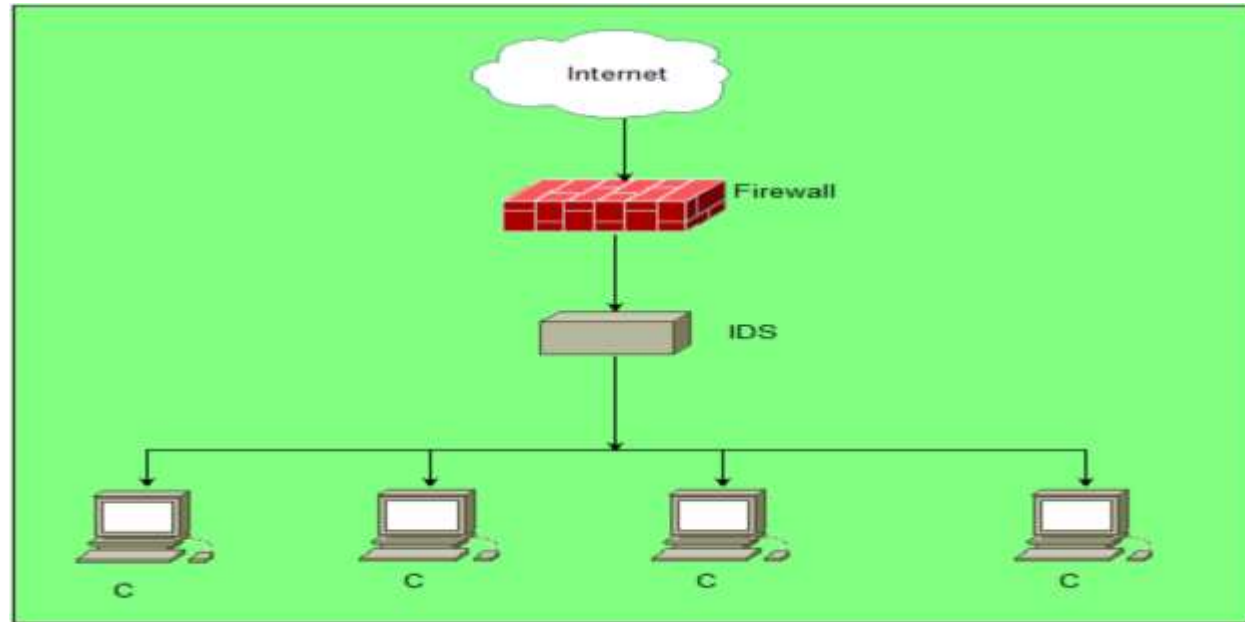
IDS Classification - Monitored Source

Network-Based IDS (NIDS):

- Network IDS is deployed in the network at selected points to recognize intrusions by inspecting packets that are transient in the network.
- Monitors network traffic across switches, routers, gateways.
- Detects port scans, DDoS, suspicious IPs, network anomalies.
- Watches overall traffic patterns for multiple systems.

IDS Classification - Monitored Source

Network-Based IDS (NIDS):



IDS Classification - Response Type

- Based on how the IDS reacts to a detection.
 - Passive Response
 - Reactive Response

IDS Classification - Response Type

Passive Response:

- A passive response typically expects to inform the administrator about the event that has occurred.
- IDS only alerts and logs the suspicious activity.
- Does not take any automatic action.
- Used where automatic blocking may disrupt business.

IDS Classification - Response Type

Active Response:

- A reactive response is utilized to counter an occurrence with a specific end goal to limit the impact of the attack.
- IDS takes automatic action after detection.
- Can block attacker IP, reset connections, change firewall rules.
- Becomes similar to an IDS + IPS combined.

IDS Classification - Detection Type

- Based on timing with which IDS analyzes data.
 - Real-Time Detection
 - Offline Detection

IDS Classification - Detection Type

Real-Time Detection:

- Analyzes packets, logs, and events as they occur.
- Real-time that endeavor to distinguish intrusions when it happens.
- Suitable for fast attacks like brute-force, scanning, ransomware.
- Requires high processing speed.

IDS Classification - Detection Type

Offline Detection:

- Analyzes stored logs or captured packets after the fact.
- Process review information with some postponement, deferring detection that happens on audit data.
- Used for forensic analysis, post-incident investigation.
- Helpful for deep-dive analysis.

IDS Classification - Data Processing Architecture

- Based on deployment architecture of IDS components.
 - Centralized IDS
 - Distributed IDS

IDS Classification - Data Processing Architecture

Centralized IDS:

- All monitoring data is collected and analyzed in one central system.
- Easier to configure and manage.
- Good for small to medium networks.
- Can become a single point of failure.

IDS Classification - Data Processing Architecture

Distributed IDS:

- Multiple IDS sensors deployed across the network.
- Each performs local analysis and reports to a central coordinator.
- Scalable, resilient, ideal for large enterprises and cloud environments.

Unit 1 - Introduction

Introduction to computer incident, legal environment, Network security and attacks, basics of incident detection, Intrusion detection system, **parameters for assessment of intrusion detection**, Detection approaches: Misuse detection, anomaly detection, specification-based detection, hybrid detection, and statistics.

Parameters for Assessment of Intrusion Detection

- Measuring IDS performance is essential to know **how well detection works, to tune systems, to compare different IDS products, and to estimate operational costs** (analyst time, hardware).
- Metrics translate alerts into actionable decisions.

Parameters for Assessment of Intrusion Detection

- **Positive data** - Attack data
- **Negative data** - Normal data.
- When an IDS tries to classify data, its decision can be either right or wrong.
- Assume that true and false stands for right and wrong, respectively.

Parameters for Assessment of Intrusion Detection

- Therefore, due to the two-class nature of the detection we have four combinations of the previous defined variables as follows:
 - True Positive (TP)
 - True Negative (TN)
 - False Positive (FP)
 - False Negative (FN)

Parameters for Assessment of Intrusion Detection

- **TP (True Positive)** — IDS raised an alert, and the event was actually an attack.
- **FP (False Positive)** — IDS raised an alert, but the event was NOT an attack (benign /normal activity).
- **FN (False Negative)** — An actual attack happened, but the IDS failed to raise an alert.
- **TN (True Negative)** — A benign/normal event occurred, and IDS did not raise an alert.

Parameters for Assessment of Intrusion Detection

	The class of actual data	The prediction of the IDS
True Positive (TP)	Attack	Attack
False Positive (FP)	Normal	Attack
True Negative (TN)	Normal	Normal
False Negative (FN)	Attack	Normal

IDS classification

Confusion Matrix

- The Confusion Matrix is a ranking method applied to any kind of classification problem.
- The size of the matrix is determined by the number of distinct classes that are to be detected.
- The aim here is to compare the actual class labels against the predicted ones.
- Consequently, the diagonal will represent all the correct classifications.

Confusion Matrix

		Predicted Class	
		Normal	Attack
Actual Class	Normal	TN	FP
	Attack	FN	TP

! The Confusion Matrix

Core metrics

- Detection Rate (DR) / True Positive Rate (TPR) / Recall
- False Positive Rate (FPR)
- Precision
- Accuracy
- F1 Score
- False Negative Rate (FNR) / Miss Rate
- True Negative Rate (TNR) / Specificity
- False Alarm Rate (FAR)

Core metrics

Detection Rate (DR) / True Positive Rate (TPR) / Recall

- Measures how many real attacks the IDS successfully detects.
- Also called Sensitivity or True Positive Rate.

$$\text{Detection Rate} = \frac{TP}{TP + FN}$$

- Higher is better.
- If too low, IDS is missing real threats.

Core metrics

False Positive Rate (FPR)

- Fraction of normal traffic wrongly flagged as an attack.
- Lower is better.

$$\text{FPR} = \frac{FP}{FP + TN}$$

- High FPR, analysts waste time investigating false alarms.

Core metrics

Precision

- Precision is the proportion of IDS alerts that are actually real attacks.
- It tells us how trustworthy an alert is.

$$\text{Precision} = \frac{TP}{TP + FP}$$

- High precision, alerts are reliable (few false alarms).
- Low precision, analysts waste time checking false positives.

Core metrics

Accuracy

- Accuracy is the overall percentage of correct decisions made by the IDS, includes detections of attacks (TP) and correct rejections of normal activity (TN).

$$\text{Accuracy} = \frac{TP + TN}{TP + TN + FP + FN}$$

- Accuracy can mislead when attack traffic is rare.
- For example, if 990 of 1000 events are normal and the IDS always says “normal,” it still gets 99% accuracy but detects no attacks (0% detection rate).

Core metrics

F1 Score

- The F1 Score is the harmonic mean of Precision and Detection Rate (Recall).
- It represents the balance between catching real attacks and avoiding false alarms.

$$F1 = 2 \times \frac{\text{Precision} \times \text{Recall}}{\text{Precision} + \text{Recall}}$$

$$F_{\beta} = (1 + \beta^2) \cdot \frac{(\text{precision} \cdot \text{recall})}{(\beta^2 \cdot \text{precision} + \text{recall})}$$

- $\beta < 1 \rightarrow$ precision is more important
- $\beta = 1 \rightarrow$ F1 score (precision = recall)
- $\beta > 1 \rightarrow$ recall is more important

- If precision or recall is very low, F1 will drop sharply.

Core metrics

False Negative Rate (FNR) / Miss Rate

- Fraction of attacks missed by the IDS.
- Lower is better.

$$\text{FNR} = \frac{FN}{TP + FN}$$

- $\text{FNR} = 1 - \text{Detection Rate (Recall)}$.

Core metrics

True Negative Rate (TNR) / Specificity

- Measures how well the IDS correctly identifies normal traffic.
- Higher is better.
- $TNR = 1 - FPR$

$$TNR = \frac{TN}{TN + FP}$$

Core metrics

False Alarm Rate (FAR)

- Proportion of all wrong decisions (both missed attacks & false alerts).
- Often used as an operational error rate.

$$\text{FAR} = \frac{FP + FN}{TP + TN + FP + FN}$$

Example

Tom is a security analyst in the Security Operations Center (SOC) of a university. During a 24-hour monitoring period, the IDS (Intrusion Detection System) generated the following observations:

- The network processed 5,000 total events (log entries / alerts / traffic entries).
- Out of these, security experts later verified that 20 events were real attacks.
- During this period, the IDS raised 30 alerts in total.
- After investigation, it was confirmed that 15 of these alerts were actual attacks.

Example

Basic Counts:

$$TP = 15$$

$$FP = 30 - 15 = 15 \text{ (because IDS alerts } 30 - 15 \text{ true} = 15 \text{ false)}$$

$$FN = 20 - 15 = 5 \text{ (20 real} - 15 \text{ detected} = 5 \text{ missed)}$$

$$\text{Normal events} = 5000 - 20 = 4980$$

$$TN = 4980 - 15(FP) = 4965$$

Example

Recall / Detection Rate (DR / TPR) = $TP / (TP + FN) = 15/(15+5) = 0.75 = 75\%$

Precision (PPV) = $TP / (TP + FP) = 15/(15+15) = 0.5 = 50\%$

False Positive Rate (FPR) = $FP / (FP + TN) = 15/(15+4965) = 0.0030 = 0.30\%$

Accuracy = $(TP + TN) / (TP + TN + FP + FN) = (15+4965)/(15+4965+15+5)$
 $= 4980/5000 = 0.996 = 99.6\%$

Example

$$\begin{aligned}\text{F1 Score} &= 2 \times (\text{Precision} \times \text{Recall}) / (\text{Precision} + \text{Recall}) \\ &= 2 \times (0.5 \times 0.75) / (0.5 + 0.75) = 0.6 = 60\%\end{aligned}$$

$$\text{False Negative Rate (FNR)} = \text{FN} / (\text{TP} + \text{FN}) = 1 - \text{Recall} = 1 - 0.75 = 0.2 = 25\%$$

$$\begin{aligned}\text{True Negative Rate (TNR / Specificity)} &= \text{TN} / (\text{TN} + \text{FP}) = 1 - \text{FPR} = 1 - 0.003 \\ &= 0.997 = 99.7\%\end{aligned}$$

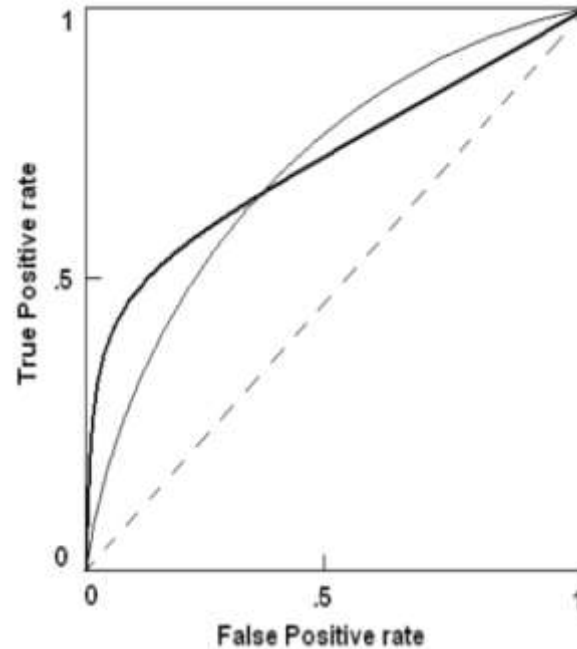
$$\text{False Alarm Rate (FAR)} = (\text{FP} + \text{FN}) / \text{Total} = (15 + 5) / 5000 = 0.004 = 0.4\%$$

Accuracy is high but precision low

ROC Curve

- ROC (Receiver Operating Characteristic) is a graph used to evaluate how well a detection system (like an IDS) can distinguish between:
 - Attack traffic (Positive class)
 - Normal traffic (Negative class)
- On the ROC curve:
 - X-axis → False Positive Rate (FPR)
 - Y-axis → True Positive Rate (TPR) / Detection Rate / Recall
- Each point on the curve represents the IDS performance at a particular threshold.

ROC Curve - Example



Unit 1 - Introduction

Introduction to computer incident, legal environment, Network security and attacks, basics of incident detection, Intrusion detection system, parameters for assessment of intrusion detection, **Detection approaches: Misuse detection, anomaly detection, specification-based detection, hybrid detection, and statistics.**

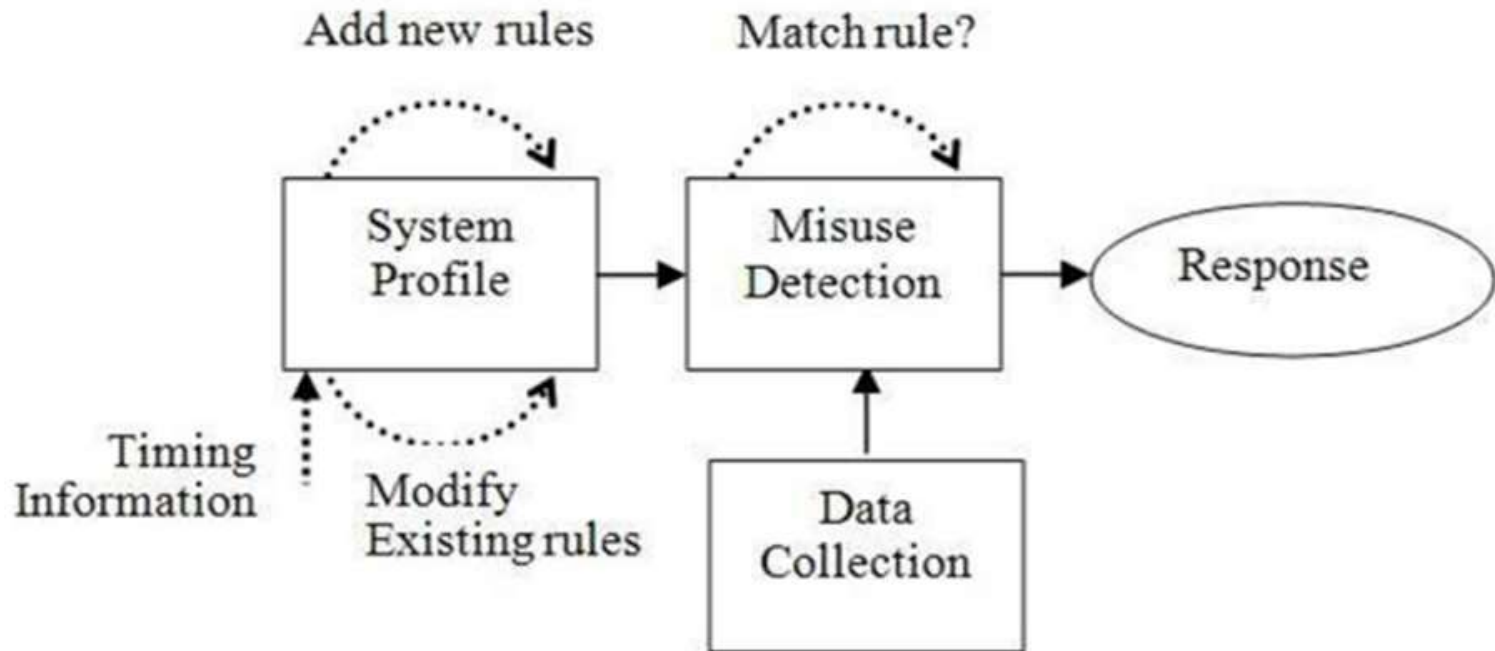
Detection Approaches

- The basic principle of intrusion detection is based on the assumption that **intrusive activities are noticeably different from normal ones** and thus are detectable.
- Categories:
 - Misuse detection
 - Anomaly detection
 - Specification-based detection
 - Hybrid detection

Misuse Detection (Signature Based Detection)

- Misuse detection is **fully effective in uncovering known attacks**, it is useless when faced with unknown or novel forms of attacks for which the signatures are not yet available.
- Moreover, for known attacks, defining a signature that encompasses all possible variations of the attack is difficult.
- Any mistakes in the definition of these signatures will increase the false alarm rate and decrease the effectiveness of the detection technique.

Misuse Detection (Signature Based Detection)



Misuse Detection (Signature Based Detection)

- The model consists of four components: namely, **data collection**, **system profile**, **misuse detection** and **response**.
- Data are collected from one or many data sources including audit trails, network traffic, system call trace, etc. Collected data are transferred into a format that is understandable by the other components of the system.
- The **system profile** is used to characterize normal and abnormal behaviors.
- The profiles characterize what a normal subject behavior should be and what operations the subjects typically would perform or do not perform on the objects.
- The profiles are matched with actual system activities and reported as intrusions in case of deviations.

Misuse Detection (Signature Based Detection)

- Four classes of techniques are commonly used to implement misuse detection
 - Pattern matching
 - Rule-based techniques
 - State-based techniques
 - Data mining

Pattern matching based intrusion detection

- Attack patterns are **modeled, matched and identified** based on the packet head, packet content or both.
- Attack patterns could also be established in host-based intrusion detection systems through concatenating the words representing the system calls in a system audit trail.
- With the continual emerging of new types and varied forms of attacks the number of signatures is constantly growing thus making the pattern matching more **expensive in terms of the computational cost**.

Rule-based expert system

- One of the earliest techniques used for misuse detection.
- Expert systems encode intrusive scenarios as a set of rules, which are matched against audit or network traffic data.
- Any deviation in the rule matching process is reported as an intrusion.
- Examples of rule-based systems include
 - MIDAS (Multics Intrusion Detection and Alerting System)
 - IDES (Intrusion Detection Expert System)
 - NIDES (Next-generation Intrusion Detection Expert System)

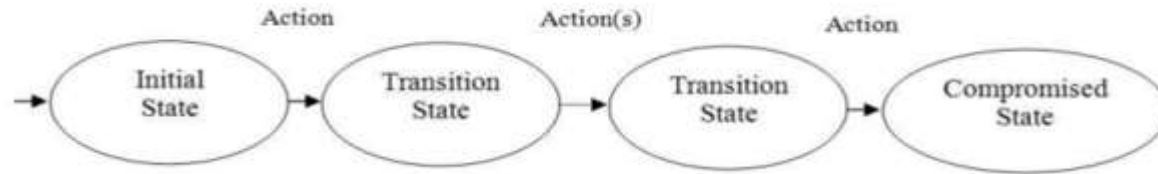
Limitations of Rule-based expert system

- Burden of **extending the rule-base** as new intrusion scenarios are discovered falls on the shoulder of the security officer.
- Developing intrusion scenarios is not an easy task and requires a certain **level of expertise** and security insight and awareness.
- Determining the **relations between rules** is difficult. When many related rules are included in an expert system, correctness of rules is difficult to verify due to the interactions among these rules.
- Consequently, in practical settings, most of the **rule bases are outdated** and quickly become obsolete.

State-based Techniques

- Detect known intrusions by using expressions of the **system state and state transitions**.
- State models simplify the specification of patterns for known attacks and can be used to describe attack scenarios easier than rule-based techniques.
- **Activities contributing to intrusion scenarios are defined as transitions between system states**, and thus intrusion scenarios are defined in the form of state transition diagrams.
- The **state of the system is a function of users or processes**.

State-based Techniques



Generic state transition diagram

- An initial state refers to the beginning of the attack.
- Compromised state stands for the successful completion of the attack.
- Transition states correspond to the successive states occurring between an initial state and a compromised state.
- An intrusion occurs if and only if a compromised state is finally reached

Techniques based on Data Mining

- Intrusion detection is considered as a data analysis process, in which data mining techniques are used to automatically discover and model features of user's normal or intrusive behaviors.
- **Three types of algorithms** are particularly useful for mining audit data, namely **classification, link analysis and sequence analysis**.
- **Classification algorithms** such as decision tree generate classifiers by learning based on a sufficient amount of normal or abnormal audit data.
- New audit data are labeled as either normal or abnormal according to the classifier.

Techniques based on Data Mining

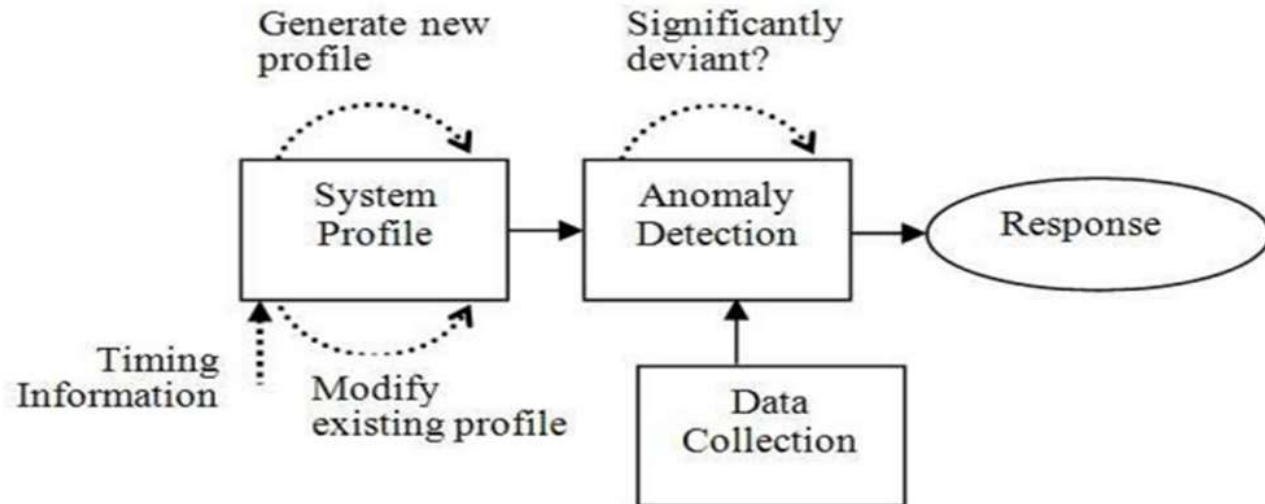
- **Link analysis** determines the relation between fields in the audit database records and normal profiles are usually derived from these relations.
- **Sequence analysis** is used to find sequential patterns in audit data and embed these patterns into intrusion detection models.

Anomaly Detection

- Different from misuse detection, anomaly detection is dedicated to establishing normal activity profiles for the system.
- It is based on the assumption that all intrusive activities are necessarily anomalous.
- It start by forming an opinion on what the normal attributes for the observed objects are, and then decide what kinds of activities should be flagged as intrusions and how to make such particular decisions.

Anomaly Detection

- The primary advantage of anomaly detection is its capability to find **novel attacks**; as such it addresses the biggest limitation of misuse detection.



Anomaly Detection

- It consists of four components: data collection, normal system profile, anomaly detection and response.
- Normal user activities or traffic data are obtained and saved by the data collection component.
- Specific modeling techniques are used to create normal system profiles
- The anomaly detection component decides how far the current activities deviate from the normal system profiles and what percentage of these activities should be flagged as abnormal.
- Finally, the response component reports the intrusion and possibly corresponding timing information.

Anomaly Detection

- As a result, the design of the detection methods and the selection of the system or network features to be monitored are two of the main open issues in anomaly detection.
- Anomaly detection techniques are divided into categories
 - Advanced statistical models
 - Rule-based models
 - Learning models
 - Biological models
 - Signal processing techniques based models

Specification-based Detection

- Specification-based detection approaches are neither misuse based, nor anomaly based since they use system **behavioral specifications to detect attacks** and premise that every well-behaved system execution shall conform to the specification of its intended behavior.
- Instead of learning system behaviors, in specification-based systems the experts' knowledge determines the **operating limits (threshold) of a system**.
- Once the correct (or allowed) system behavior is specified the events deviating from the specification would generate an alert.

Hybrid Detection

- Early research works on intrusion detection systems suggested that the intrusion detection capabilities can be improved through a hybrid approach consisting of both signature (misuse) detection as well as anomaly detection.
- In such a hybrid system, the signature detection technique detects known attacks and the anomaly detection technique detects novel or unknown attacks.

Thank you